

Trust by Construction: Secure-by-Design Patterns for Agentic AI in Learning Institutions

Scale Intelligence Without Scaling Implicit Authority

Rachna Srivastava

Enterprise Architect | AI Systems Researcher | Independent work, in a personal capacity

genaiworks@gmail.com | UNU Macau AI Conference 2026 | Extended abstract

AI × Education: AI for Learning, Learning for AI

1. Authority before autonomy

AI agents in learning institutions can read student records, change systems and delegate to other agents. A transcript assistant should retrieve the named record, propose a correction and deliver the approved result to the registrar. It should not open another student's file because a document tells it to, approve its own correction, or keep releasing data after revocation. Indirect prompt injection can redirect tool-integrated agents [1].

The harder problem is that permitted steps combine into an outcome no one allowed. A reader, a summariser and a publisher may each hold a sound tool list and still form a path from a transcript to a public page. Each step meets its local rule; the chain breaches the task boundary.

Trust by Construction treats every agent, its coordinator included, as an untrusted proposer. Separate services mediate protected reads, delegation, effects and disclosure under one rule: proof before power. The contribution is ten patterns for executable policy refusals, a proposed composition contract for delegated work, and an offline evidence kit.

The work builds on control-flow separation [2], information-flow control [3] and agent design patterns [4]. It integrates these approaches around delegated authority, shared budgets and revocation. The aim is an integration and test method, not a new primitive. Proof means checking stated rules against trusted state, not that a model is truthful or a grade fair.

2. Ten patterns, one boundary, and a swarm contract

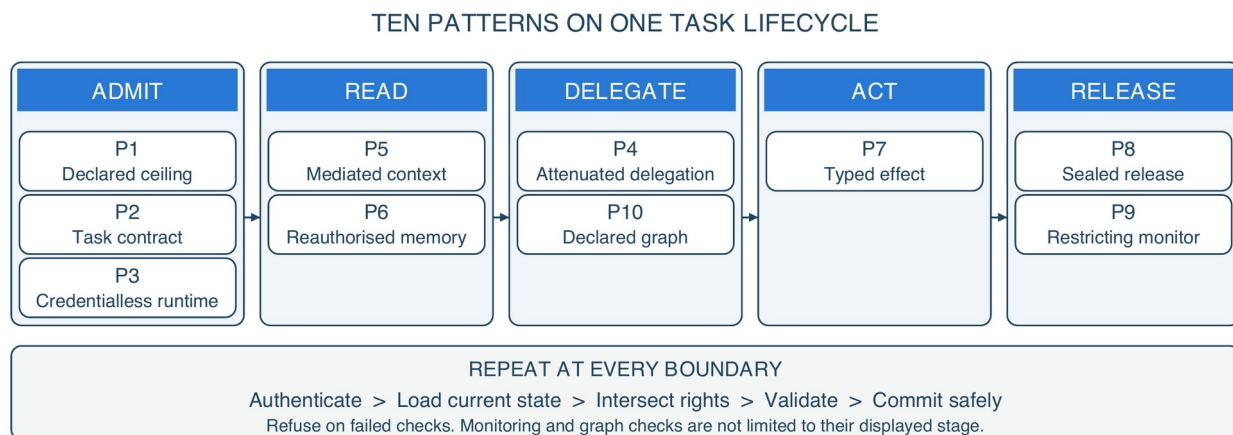


Figure 1. Ten patterns across one task lifecycle. Columns show each pattern's primary stage.

The model makes proposals. Separate, trusted software decides which operations may run. A task contract has seven fields: task, purpose, subject, tenant, scope, budget and expiry, where scope is an exact-match set over nine axes and budget a ceiling over six. Scoped leases let an agent call the gateway without letting it rewrite the policy. The ten patterns are a declared authority ceiling (P1), a task contract (P2), a credentialless runtime

(P3), attenuated delegation (P4), mediated context (P5), reauthorised memory (P6), typed effects (P7), sealed release (P8), a restricting monitor (P9) and a declared task graph (P10).

The threat model allows malicious or colluding agents, poisoned content and a monitor that is wrong. It assumes trusted enforcement code and operators, protected state and adapters that cannot be bypassed. A purpose picks an approved operation and resource policy; it does not establish what the agent means.

Every boundary does the same five things: authenticate the caller, load current state, intersect rights, validate the exact operation, then commit. The case makes it concrete. A registrar asks for a grade correction. The assistant may read the named record, because the lease names that record and no other. It drafts a change, but the write is refused until the instructor confirms, because the contract names a second approver. The approval binds to the exact draft, so a different write cannot reuse it. Revoke the grant mid-task and the queued write fails, even though it was approved when it was drafted.

ONE GRADE CORRECTION THROUGH THE GATE

Worked example under trusted enforcement and complete mediation

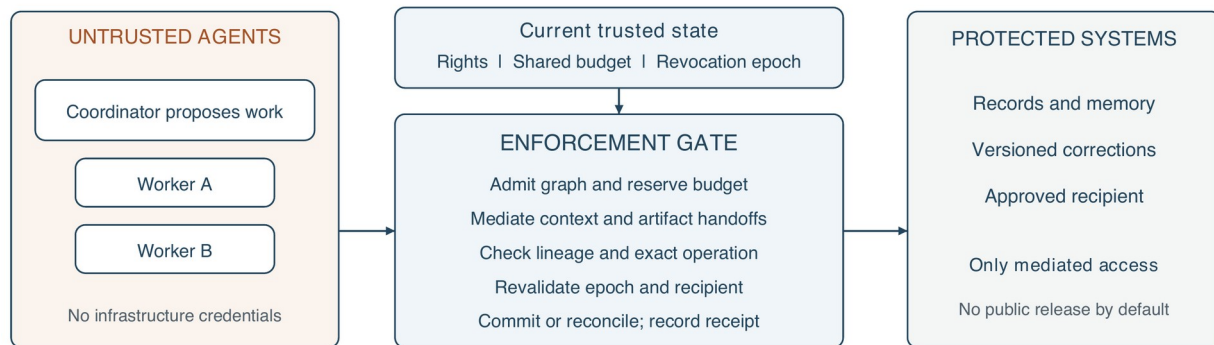
Step	Assistant proposes	Trusted gate checks	Outcome
LEASE	Work on record S-1042	Lease names only that record.	Scoped
READ	Read S-1042	Scope and current state match.	Allowed
DRAFT	Execute a grade change	Instructor approval is absent.	Refused
APPROVE	Instructor confirms draft	Approval binds the exact digest.	Bound
COMMIT	Execute approved draft	Epoch, scope and approval checked.	Allowed
SUBSTITUTE	Execute a different draft	The digest no longer matches.	Refused
REVOKE	Execute queued write	The task epoch is stale.	Refused

No claim of grade correctness follows from authorisation. Domain rules and qualified adapters remain necessary.

Figure 2. One grade correction, end to end. Trusted services check stated rules at each boundary under the declared enforcement assumptions.

The design hypothesis is falsifiable: under an unchanged contract, adding workers must not admit a prohibited effect, information path or total spend. That must be checked on the whole composition, not on each worker.

ONE TASK ENVELOPE ACROSS PARALLEL WORKERS



Unknown state, exhausted budget or stale epoch: refuse the protected operation.

Figure 3. Proposed swarm extension. Parallel workers share one task budget and revocation epoch; every handoff crosses enforcement. The diagram specifies architecture, not measured distributed performance.

A swarm is a set of agents on one institutional task. The coordinator may split work and propose workers, but spawning is itself mediated. Each child gets its own identity, an expiry and authority no wider than its ancestors, task and workload ceiling; per-agent identity supports traceability [5]. Replanning changes the task

graph, and a trusted gate must admit each new node and edge before use. Agreement among agents is evidence for review, never a credential.

Parallelism must not multiply resources. All descendants share limits for calls, context and memory bytes, traffic bytes, compute units and cost, plus a workload ceiling across tasks. Depth, population and time limits bound recursive spawning. Atomic reservations precede dispatch; completion or cancellation settles them without double spending. External effects need adapter reconciliation when the outcome is unclear: a rollback cannot unsend an email.

Information composes the same way. Trusted mediation binds source labels to artifacts and messages, so agents cannot strip them by rewording or dropping citations. Outputs inherit restrictions from all exposed context, including memory. Reuse with a clean context needs a new isolated context; an agent's claim to have forgotten is not enough. Combining inputs intersects recipients and purposes, and relaxation needs a separately authorised release. This can over-restrict useful summaries, a deliberate trade.



Figure 4. Composition changes the security question. A tool allowlist does not stop a permitted publisher disclosing another agent's protected input. Labels and recipient checks must survive the handoff; agreement among agents supplies no release authority.

At fan-in, a trusted gate checks provenance, authority, artifact identity and destination before accepting results. Revocation raises the task epoch, so queued work, stale leases and later release chunks fail revalidation. Disclosed information cannot be recalled. A fresh check alone leaves a check-then-act race: strict revocation needs authorisation and commit serialised against it, or an adapter that rejects stale epochs. Partitioned workers must stop when freshness cannot be shown, trading availability for bounded authority. Physical isolation, egress control and connectors stay deployment duties.

3. Evidence, falsification and impact

ONE CONTRACT ACROSS SIX SYNTHETIC DOMAIN PACKS

The same enforcement code and authored scenario suite are reused

Domain pack	Governed object	States explored	Hostile blocked	Benign completed
Student support	Support cases and recommendations	240	30 / 30	6 / 6
Academic records	Grade corrections and transcripts	4,800	30 / 30	9 / 9
Corporate data	Answers from confidential records	8,400	30 / 30	10 / 10
Health records	Access to and summaries of charts	20,160	30 / 30	12 / 12
Consumer finance	Credit, fraud and customer answers	8,400	30 / 30	10 / 10
Public benefits	Benefit decisions and notices	13,440	30 / 30	11 / 11
Total	Six synthetic packs	55,440	180 / 180	58 / 58

Each pack retains its own denominators. These are linked synthetic checks, not independent attacks or sector compliance evidence.

Figure 5. One evaluation approach across six synthetic sector profiles. Domain policies and permitted transitions vary; each pack requires its own evidence.

The FSSAI-RA reference kernel runs offline, without model weights or a GPU. One contract and one refusal suite cover six synthetic packs: student support, academic records, corporate data, health records, consumer finance and public benefits. Across them the evaluation explores 55,440 bounded configurations with no violation, 180 hostile scenarios, all contained, and 58 benign workflows, all completed [6]. The packs reuse an authored scenario suite: these are linked synthetic checks, not 180 independent attacks, outside validation or reliability estimates.

DELEGATION CHECKS ACROSS THREE AUTHORED ARMS

Identical synthetic chains; this is not a benchmark of cited third-party systems

Scenario	A Unguarded	B Per hop	C Whole chain	Whole-chain outcome
Bearer chain reuse	Passed	Passed	Blocked	requester not chain leaf
Confused deputy	Passed	Passed	Blocked	out of effective scope
Undisclosed beneficiary	Passed	Passed	Blocked	beneficiary scope exceeded
Scope reamplification	Passed	Blocked	Blocked	scope not attenuated
Authority laundering	Passed	Passed	Blocked	chain cycle
Orphaned delegation	Passed	Passed	Blocked	delegation outlives delegator
Unrooted chain	Passed	Passed	Blocked	chain not rooted
Depth evasion	Passed	Passed	Blocked	depth exceeded
Machine delegated consequence	Passed	Passed	Blocked	consequence not delegable
Forged hop	Passed	Blocked	Blocked	delegation key untrusted
Benign two hop	Completed	Completed	Completed	admitted
Hostile chains blocked	0 / 10	2 / 10	10 / 10	Nine control ablations restore associated violations

Blocked means a hostile chain was refused. Completed means the benign workflow succeeded. Passed means the hostile chain was admitted.

Figure 6. Ten synthetic delegation risk classes across three authored architectures. Blocked means a hostile chain was refused; Completed means the benign chain succeeded.

Four findings explain why these checks matter. First, composition is not covered by local correctness. Against ten delegation attacks, an unguarded chain contained none, per-hop validation against the immediate delegator contained two, and whole-chain verification contained ten. These are authored baselines, not evaluations of those cited systems. Removing each of nine controls restores its associated violation in the ablation suite.

Second, sequence testing found what step testing missed: a stateful harness caught a summary drafted while access was valid but released after consent was withdrawn, which single-step enumeration passed. Release now rechecks live state; removing it brings the violation back.

Third, the academic-records profile exposed an approval role omitted from the runtime map, which covered only consequential rules. The fix enforces declared roles on every transition; regression tests cover refusals and valid approvals.

Fourth, a simulation models finite oversight. Across forty cases, simulated reviewers attentive for the first 2, 4, 8 or 16 cases produced 5, 5, 4 and 3 harmful approvals. A minimum review time deferred work to a manual route and prevented these simulated approvals. No human reviewers were observed; waiting longer does not establish careful judgment. Manual-route outcomes were not evaluated.

SIMULATED OVERSIGHT UNDER DECLARED ATTENTION LIMITS

Forty synthetic cases; no human participants or observed error rates

		DECLARED MINIMUM DELIBERATION TIME				
		None	5 s	15 s	45 s	90 s
Declared attentive cases out of 40	2	5 0 deferred	0 38 deferred	0 38 deferred	0 38 deferred	0 38 deferred
	4	5 0 deferred	0 36 deferred	0 36 deferred	0 36 deferred	0 36 deferred
	8	4 0 deferred	0 32 deferred	0 32 deferred	0 32 deferred	0 32 deferred
	16	3 0 deferred	0 24 deferred	0 24 deferred	0 24 deferred	0 24 deferred
	40	0 0 deferred	0 0 deferred	0 0 deferred	0 0 deferred	0 0 deferred

Large numbers show harmful approvals in the simulation; smaller labels show deferred cases.

Positive tested floors remove the simulated approvals by deferral, not by improving reviewer judgment.

Elapsed time does not prove attention. Manual fallback outcomes and real reviewer behaviour are unmeasured.

The sweep also detects inconsistency between declared quotas and deliberation floors.

Figure 7. Simulated oversight under declared attention budgets. Cells show harmful approvals in forty synthetic cases. Deferral removes the tested simulated approvals; no human reviewers were observed, and elapsed time does not establish careful judgment.

IMPLEMENTATION STATUS AND TEST EVIDENCE

Built means exercised in the reference kernel, not proven secure in production

Claim	Enforcement mechanism	Status	Named evidence
Delegation cannot enlarge authority	Attenuated lease; ancestor intersection	BUILT	test_lease_cannot_expand_any_authority_axis
Parallel siblings cannot multiply a budget	One task envelope; atomic reservation	BUILT	test_aggregate_sibling_budget_does_not_multiply
Separate processes cannot race a commit	Serialised authorisation and commit	BUILT	test_independent_processes_serialize_budget_and_release
Composition cannot erase a restriction	Bound source labels; recipient checks	BUILT	test_potential_source_to_sink_path_denied_even_for_clean_message
Memory cannot carry a restriction away	Reauthorised memory; restart persistence	BUILT	test_restart_preserves_memory_restrictions_budget_and_rejects_legacy_adapter
Revocation invalidates in-flight authority	Task epoch revalidated at every use	BUILT	test_effect_approval_substitution_and_guardian_epoch_invalidation
A release cannot resume after revocation	Per-chunk reauthorisation	BUILT	test_stream_reauthorizes_every_chunk_and_bulk_cannot_bypass
Checking each step is not checking the sequence	Stateful harness against a reference model	BUILT	test_stateful_sequences_hold_and_find_counterexamples_when_a_control_is_removed
The same bound holds across distributed workers	Shared epoch and reservations	PROPOSED	Evaluation plan in section 3
A delivered external effect can be undone	Adapter reconciliation only	NOT CLAIMED	Stated limit

Distributed deployment remains proposed. External effects already delivered cannot be recalled.

Figure 8. Implemented controls and proposed extensions. Named tests exercise bounded instances of each claim; they do not establish universal guarantees.

Eight implemented controls have named regression tests for authority growth, shared budgets, inherited restrictions and stateful sequences. Passing these tests supports the bounded claims under the stated assumptions; it does not prove them for all inputs. Every comparison arm completed its benign fixtures with no false denials in that set. These limited fixtures establish neither general utility nor latency, staffing or

deployment cost. The same bound across distributed workers is specified, not evaluated. Undoing a delivered external effect is not claimed.

The next evaluation should compare an unmediated swarm, local controls, shared enforcement and a deny-all baseline under one workload, raising worker count and depth, and run against a public injection benchmark [7]. A single prohibited composite outcome falsifies the claim.

Security stays conditional on complete mediation and sound policy. A compromised enforcer, covert channel or permissive policy invalidates containment; a malicious monitor can deny service without escalating privilege. Authorised actions may still be inaccurate, discriminatory or harmful, so review, appeal, accessibility and pedagogical evaluation stay necessary. A decision receipt binds policy version, task epoch, source lineage, artifact digest, recipient and outcome, so review need not treat model reasoning as proof. Receipts need access controls and retention limits, so the trail is not another store of student data.

For institutions, trust becomes something a buyer can demand and an auditor can rerun: named enforcement points, a filled contract, declared review limits and fresh evidence. Procurement can require the refusal suite before signing; a regulator can check purpose and revocation as running controls, not text. A model or vendor change requires fresh adapter checks and the same refusal tests. Sovereignty becomes control of keys, data flow and exit, not server location.

4. Conclusion: scale intelligence, bound authority

For AI for Learning, a registrar can inspect record access, correction authority and release destinations. Institutions should deploy bounded, reversible workflows first, qualify connectors, and evaluate with staff and students before expanding autonomy. A named owner must handle escalation and appeals, and students must be told how to contest a result. Institutions must validate review capacity in practice; excess work should queue or reduce autonomy rather than rely on nominal approval.

For Learning for AI, learners can inspect a forged approval, poisoned memory and a colluding agent chain, then observe which boundary refuses each action. This complements UNESCO's human-centred AI competency agenda [8] with practical understanding of authority and redress, and offline verification reduces computing needs for the teaching lab.

The design aims to support SDG 4 through accountable school workflows and SDG 16 through contestable institutional authority; educational outcomes remain to be evaluated. Because the contract is enforced outside the model, institutions can require the same authority contract and refusal suite across model and vendor changes, so governance attaches to a workflow whose authority can be withdrawn rather than to a vendor's assurances.

More capable models introduce risks beyond authority control. This contribution addresses one tractable requirement: increased autonomy must not silently expand an institutional mandate.

References

- [1] Zhan, Q., et al. (2024). InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. Findings of ACL. <https://arxiv.org/abs/2403.02691>
- [2] Debenedetti, E., et al. (2025). Defeating Prompt Injections by Design. arXiv:2503.18813. <https://arxiv.org/abs/2503.18813>
- [3] Costa, M., et al. (2025). Securing AI Agents with Information-Flow Control. arXiv:2505.23643. <https://arxiv.org/abs/2505.23643>
- [4] Beurer-Kellner, L., et al. (2025). Design Patterns for Securing LLM Agents against Prompt Injections. arXiv:2506.08837. <https://arxiv.org/abs/2506.08837>
- [5] Chan, A., et al. (2024). Visibility into AI Agents. ACM FAccT. <https://arxiv.org/abs/2401.13138>
- [6] Srivastava, R. (2026). FSSAI-RA reference implementation. Repository snapshot 9bb35a1. Evidence: [fssai-ra/evaluation/results/](https://github.com/genaiworks/fssai-ra/tree/9bb35a1); regression tests: [fssai-ra/tests/test_tbc_sdk.py, test_delegation.py and test_generalization.py](https://github.com/genaiworks/fssai-ra/tree/9bb35a1). <https://github.com/genaiworks/fssai-ra/tree/9bb35a1>
- [7] Debenedetti, E., et al. (2024). AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. NeurIPS Datasets and Benchmarks. <https://arxiv.org/abs/2406.13352>
- [8] UNESCO (2024). AI Competency Framework for Students. <https://unesdoc.unesco.org/ark:/48223/pf0000391105>

Implementation appendix

Supporting material. The submitted extended abstract is the four sections above; this appendix is for the reader who intends to build it. This work was carried out independently and in a personal capacity: it does not represent the position of the author's employer or of any other institution, and the implementation, the evaluation and every figure here are the author's own.

The architecture is not specific to education. One contract and one refusal suite cover the six packs in section 3, and the worked case in Figure 2 requires domain-specific policy, approval roles and qualified adapters when applied to a patient chart or a benefits claim.

A. The ten patterns, as contracts you can implement

A pattern here is not advice. Each names a rule, the refusal it must produce when that rule is broken, and where it binds in the reference kernel. A pattern with no refusal is not implemented.

TEN PATTERNS AS IMPLEMENTABLE CONTRACTS

Rules, refusal codes and enforcement components

ID and pattern	Rule	Refusal or restriction	Component
P1 Declared authority ceiling	The operator installs a workload's maximum authority. A model never requests it.	ENVELOPE_DENIED	tbc/contracts.py Passport
P2 Task contract	Every task names purpose, subject, tenant, scope, budget and expiry before work starts.	INVALID_TASK_FIELDS	TaskContract, create_task
P3 Credentialless runtime	The component that reasons holds no store credential and no write credential.	no path exists	TrustRuntime.dispatch
P4 Attenuated delegation	A child holds the intersection of every ancestor, and expires no later than its parent.	SCOPE_NOT_ATTENUATED	delegation.py, spawn_agent
P5 Mediated context	The gate alone reads records, and returns grant $\cap$ request $\cap$ live consent $\cap$ zone.	CONTEXT_SCOPE_DENIED	request_context
P6 Reauthorised memory	Stored context carries provenance and retention, and is rechecked against live authority.	MEMORY_REAUTHORIZATION_DENIED	persist_memory, read_memory
P7 Typed effect	An effect names operation, resource, expected version and state; approval signs that digest.	RESOURCE_RIGHTS_DENIED	propose_effect, execute_effect
P8 Sealed release	Release is a named review of exact bytes to an authenticated recipient, used once.	DESTINATION_DENIED	authorize_release, collect_release
P9 Restricting monitor	A monitor may contract authority. It can never grant any.	contraction only	Guardian
P10 Declared task graph	The agent and message graph is declared; a gate admits each node and edge before use.	AIRLOCK_CHANNEL_DENIED	Guardian._evaluate_locked

P3 removes direct credential access; P9 restricts authority. Those two rows describe properties, not refusal codes.

Figure 9. The ten patterns as implementable contracts. Refusal codes are the stable strings the reference kernel returns; they are what an auditor greps for and what a test asserts on.

B. The two artifacts everything else hangs from

TASK CONTRACT AND DECISION RECEIPT

Contract fields are code-derived; receipt content below is a conceptual summary

Artifact or check	Fields and purpose
Task contract fields	task, purpose, subject, tenant, scope, budget, expires
Scope axes	models, data_classes, zones, tools, resources, destinations, operations, channels, memory
Budget dimensions	calls, context_bytes, memory_bytes, traffic_bytes, compute_units, cost_microunits
Receipt content to bind	Policy version; task epoch; source lineage; artifact digest; recipient; outcome.
Authority and freshness	Validate current scope and ancestor rights; reject stale epochs.
Identity and exactness	Authenticate the requester and recipient; bind approval to exact bytes.

Trusted services install contracts and issue receipts. Protect identifiers and digests with access controls and retention limits.

Figure 10. The task contract and the decision receipt. Scope is exact-match: there are no wildcards, and an unknown identifier is a refusal rather than a match.

A task contract is what an institution fills in before an agent starts; a decision receipt is what it reads afterwards. Both are small, both sit outside the model, and every refusal in Figure 9 is a comparison between them and live state.

C. The order to build it in

Nothing here requires adopting all ten patterns at once. Each stage below is independently useful, ships a refusal a buyer can test, and names what is still open after it.

A STAGED ADOPTION PATH

Each step adds a control that an institution can test

Step	Pattern or control	Implementation	Added control	Still open
1 Remove direct credentials	P3	Put store and write credentials in trusted services.	Protected operations cross a gate.	The gate and policy can still fail.
2 Declare the task	P1, P2	Record purpose, subject, scope, budget and expiry.	An inspectable authority ceiling.	Approval may not bind the final action.
3 Bind approval to the action	P7	Bind approval to digest, resource version and expiry.	Substitution can be refused.	Delegation may still amplify rights.
4 Verify the complete chain	P4, P10	Check ancestors, graph, depth and population.	Bounds apply to the declared chain.	Information can still leave via a permitted path.
5 Preserve labels at release	P5, P6, P8	Carry source restrictions through context, memory and release.	Recipient and lineage checks persist.	Human review can still be ineffective.
6 Enforce review capacity	Review-load controls	Declare and enforce quotas, floors and escalation.	Excess work is deferred.	Human calibration and field outcomes remain open.

Credential separation removes one direct path to institutional authority; it does not prevent every agent incident.

Figure 11. Six staged adoption steps, with the control each adds and the assurance that still requires evaluation.

D. What this adds to the work it builds on

RELATIONSHIP TO PRIOR WORK
Conceptual mapping of design ideas and the focus of this contribution

Work	Relevant foundation	Integration focus
Control-flow separation [2]	Separates trusted control flow from untrusted data; uses capabilities to constrain tool access.	Apply explicit authority checks to task delegation and exact effects.
Information-flow control [3]	Tracks confidentiality and integrity labels and enforces policies over data flows.	Carry restrictions across task handoffs, memory and release.
Agent design patterns [4]	Analyses security patterns and their utility trade-offs using case studies.	Express a task lifecycle as refusal tests, contracts and an evidence kit.
Trust by Construction	Integrates declared authority, budgets, revocation and review-load controls.	Local synthetic tests and ablations; distributed and educational outcomes remain to be evaluated.

This chart does not claim that prior work lacks multi-agent controls or that this implementation outperforms it.

Figure 12. Relationship to prior work. The contribution integrates existing control and information-flow ideas with task-wide authority, budgets and revocation. This is a conceptual mapping, not a head-to-head benchmark.

E. Reproducing every number in this paper

The kernel requires no model weights or GPU. After installing the dependencies, run from the fssai-ra directory. Transport tests use local sockets.

```
pip install -e ".[dev]"          # include test dependencies
pytest                          # the full offline suite
python scripts/generate_results.py --check  # committed results match a fresh run
```

The result-generation command checks the committed evaluation artifacts against a fresh run and also exercises local transport. Every count in section 3 is a fixture observation on synthetic packs authored here: evidence that the controls bind where the paper says they bind, not a field outcome and not a claim about educational benefit.